Article conceptuel (cadre de recherche) · 18 octobre 2026

L’intelligence artificielle dans le triage des alertes des SOC

Le rôle modérateur de l’hygiène informatique, du Zero Trust et de la fragmentation des outils

Innocent Twagirumukiza

Résumé

L’effet de l’intelligence artificielle (IA) sur le triage des alertes d’un centre opérationnel de sécurité (SOC) dépend de la qualité de l’environnement dans lequel elle est déployée. Cet article propose un cadre conceptuel pour examiner cette thèse. Sa question de recherche est la suivante : si et comment la maturité de l’hygiène informatique, la cohérence de la mise en œuvre du Zero Trust et le degré de fragmentation des outils modifient l’effet de l’IA, par rapport à un triage conventionnel, sur la qualité de détection et sur le coût d’investigation.

Le cadre distingue le volume informationnel du bruit informationnel. Il traite l’usage de l’IA comme variable centrale, les trois facteurs comme modérateurs, et le volume d’alertes ainsi que la complexité de configuration des règles comme variables de contrôle. Quatre propositions de recherche sont formulées, chacune assortie de sa direction attendue et de son critère de réfutation. Un protocole de validation en deux phases est proposé : une étude qualitative exploratoire, puis une analyse multiniveau complétée par un rejeu d’alertes étiquetées.

L’article ne rapporte aucun résultat empirique. Il vise à fournir une base testable pour déterminer dans quelles conditions l’IA réduit réellement le bruit informationnel plutôt qu’elle n’automatise les défauts existants.

Mots-clés : SOC, triage des alertes, bruit informationnel, intelligence artificielle, hygiène informatique, Zero Trust, fragmentation des outils, effet de modération, décision humaine.

1. Introduction

Les SOC concentrent la surveillance, la détection, l’analyse et la réponse aux incidents. Ils s’appuient sur des solutions de gestion des événements de sécurité, de détection sur les terminaux, de renseignement sur les menaces et d’orchestration des réponses. La multiplication des environnements cloud, la généralisation des identités numériques et la croissance des sources de télémétrie augmentent le volume de données à exploiter, et les organisations empilent des outils spécialisés pour couvrir des périmètres toujours plus étendus.

La littérature décrit les conséquences humaines de cette situation. Tariq et al. (2025) dressent un état des lieux de la recherche sur la fatigue des alertes dans les SOC. Alahmadi et al. (2022) et Kokulu et al. (2019) rapportent, à partir d’entretiens avec des analystes, les difficultés liées à la pertinence des alarmes et à l’adéquation entre outils, processus et personnes. Vielberth et al. (2020) proposent une étude systématique des SOC et de leurs défis ouverts. Ofte et Katsikas (2023) examinent la conscience situationnelle des opérateurs.

Face à ces difficultés, l’IA est de plus en plus présentée comme un levier de priorisation, de corrélation et de synthèse des alertes. Chhetri et al. (2024) étudient à cet égard la coopération entre analystes et IA. Mais l’IA s’insère dans un environnement déjà structuré, avec ses règles de détection, ses outils et ses pratiques de sécurité, et rien ne permet de supposer que son apport soit identique d’un SOC à l’autre.

1.1 La lacune visée

Les travaux cités examinent le plus souvent la charge d’alertes, la coopération humain-IA ou la conscience situationnelle. L’articulation entre l’effet de l’IA et la qualité de l’environnement technique et organisationnel est moins formalisée. L’hypothèse de travail de cet article est que cette lacune existe et qu’elle est importante ; la revue ciblée décrite en section 5 doit le confirmer ou l’infirmer avant toute soumission.

Une IA de triage consomme du contexte : identifiants d’actifs, propriétaires, historique des comptes, état des correctifs, posture des terminaux, journaux issus de plusieurs outils. Si ce contexte est incomplet, incohérent ou dispersé, l’IA peut aller plus vite sans mieux décider. À l’inverse, un environnement maîtrisé peut permettre à l’IA de produire un gain réel. Le contexte n’est donc pas une simple variable de confusion : il peut conditionner l’effet que l’on cherche à mesurer.

1.2 Question de recherche

Comment la maturité de l'hygiène informatique, la cohérence de la mise en œuvre du Zero Trust et le degré de fragmentation des outils modifient-ils l'effet de l'intelligence artificielle, par rapport à un triage conventionnel, sur la qualité de détection et sur le coût d'investigation lors du triage des alertes dans les SOC ?

Trois sous-questions la déclinent :

1. **SQ1 (hygiène).** L'avantage de l'IA sur le triage conventionnel est-il plus marqué lorsque l'hygiène informatique est plus mature ?
2. **SQ2 (fragmentation).** Cet avantage diminue-t-il lorsque les outils sont fragmentés et peu interopérables, ou l'IA compense-t-elle au contraire cette fragmentation ?
3. **SQ3 (Zero Trust).** Pour les alertes liées aux identités et aux accès, une mise en œuvre cohérente du Zero Trust accroît-elle l'avantage de l'IA ?

Les deux résultats sont examinés ensemble : un gain de temps obtenu au prix de menaces manquées ne constitue pas une amélioration.

1.3 Contributions et plan

L'article apporte trois éléments : une définition fonctionnelle du bruit informationnel distincte du volume et de la fatigue des alertes ; un cadre de modération dans lequel l'IA est la variable centrale et trois caractéristiques de l'environnement sont des modérateurs ; quatre propositions falsifiables avec un protocole de validation. La section 2 examine la littérature, la section 3 présente le cadre, la section 4 formule les propositions, la section 5 décrit la méthode de validation, et les sections 6 à 8 traitent de la discussion, des limites et de la conclusion.

2. Revue de la littérature

Cette revue est volontairement ciblée sur ce qui fonde le modèle. Elle reste préliminaire : la section 5 prévoit une revue reproductible avant soumission.

2.1 Volume d'alertes et fatigue

La fatigue des alertes désigne la dégradation de l'attention ou de la vigilance susceptible d'apparaître lorsque les analystes traitent de nombreuses alertes dont la pertinence est faible ou difficile à établir (Tariq et al., 2025). Le nombre d'alertes mesure la charge, pas la difficulté du travail : deux SOC recevant autant d'alertes peuvent faire face à des efforts très différents selon le contexte disponible, la redondance et les procédures d'investigation. Il faut donc distinguer le volume d'événements collectés, le volume d'alertes générées, la proportion d'alertes pertinentes, la difficulté de qualification et la qualité des décisions finales.

2.2 L'IA dans le triage et la coopération humain-IA

L'IA peut prioriser des alertes, rapprocher des événements, résumer un contexte et automatiser des tâches répétitives. Chhetri et al. (2024) soutiennent l'intérêt d'une coopération où l'automatisation traite les tâches adaptées et où l'expertise humaine reste mobilisée pour les cas ambigus. Les travaux sur l'automatisation montrent toutefois que la confiance excessive et la complaisance sont des risques connus (Parasuraman et Riley, 1997 ; Parasuraman et Manzey, 2010). Une IA qui traite plus d'alertes en moins de temps n'améliore donc la sécurité que si le risque de manquer une menace pertinente ne s'accroît pas. Cette réserve justifie de mesurer ensemble le coût d'investigation et la qualité de détection.

2.3 Fragmentation des outils et perte de contexte

Les SOC combinent plusieurs technologies spécialisées. Cette diversité améliore la couverture mais peut dégrader l'intégration : identifiants différents pour un même actif, alertes redondantes, contexte à reconstituer manuellement à travers plusieurs interfaces. Kokulu et al. (2019) documentent des décalages entre technologies, processus et personnes dans les SOC. La variable pertinente n'est pas le nombre de produits, mais l'interopérabilité, la cohérence sémantique des données et le partage du contexte entre composants. Un environnement composé de nombreux outils bien intégrés n'est pas fragmenté au sens de ce modèle.

2.4 Hygiène informatique

L’hygiène informatique regroupe les pratiques de base qui maintiennent un environnement maîtrisé : inventaire des actifs, gestion des correctifs, administration des comptes et des privilèges, configuration sécurisée. L’ANSSI (2017) en propose un référentiel de mesures. Pour un SOC, ces pratiques déterminent la facilité avec laquelle une alerte peut être rattachée à un actif et à un responsable, et la stabilité des comportements de référence. Une amélioration de l’hygiène peut cependant révéler des événements jusque-là invisibles et augmenter temporairement les détections ; l’effet attendu porte donc sur l’interprétabilité des alertes, pas sur leur nombre.

2.5 Zero Trust

Le Zero Trust repose sur la vérification explicite des accès, le moindre privilège et l’évaluation du contexte et du risque à chaque demande (Rose et al., 2020). Le modèle de maturité de la CISA (2023) structure sa mise en œuvre en piliers, dont l’identité et les terminaux. Les contrôles associés produisent des informations sur les identités, les appareils et les conditions d’accès qui, corrélées à d’autres sources, peuvent aider à qualifier une alerte d’accès. Mais des politiques mal harmonisées peuvent aussi multiplier les refus et les changements de contexte. Le Zero Trust n’est donc ni une source intrinsèque de bruit ni une garantie de réduction du bruit. Son rôle dans ce modèle est restreint aux alertes liées aux identités et aux accès, où il fournit du contexte.

2.6 Synthèse et appui actuel

Le tableau suivant indique, pour chaque élément du modèle, le rôle supposé et le degré d’appui documentaire dont dispose actuellement cet article. Il met en évidence les parties à consolider par la revue ciblée.

Élément	Rôle supposé dans le modèle	Appui documentaire actuel
Fatigue et volume d’alertes	Variable de contrôle	Solide (Tariq et al., 2025 ; Alahmadi et al., 2022)
Coopération humain-IA	Cadre du triage assisté	Partiel (Chhetri et al., 2024 ; Parasuraman et Manzey, 2010)
Fragmentation des outils	Modérateur	Partiel, surtout qualitatif (Kokulu et al., 2019)
Hygiène informatique	Modérateur	Référentiels (ANSSI, 2017), peu de travaux sur le lien avec le SOC
Zero Trust	Modérateur, alertes d’identité et d’accès	Référentiels (Rose et al., 2020 ; CISA, 2023), peu de travaux sur le lien avec le SOC
Interaction entre ces facteurs et l’IA	Cœur de la contribution	À établir par la revue ciblée

La lacune est donc moins l’absence de littérature sur chacun des facteurs que l’absence, à notre connaissance, d’un cadre qui les articule comme modérateurs de l’effet de l’IA sur le triage.

3. Cadre conceptuel

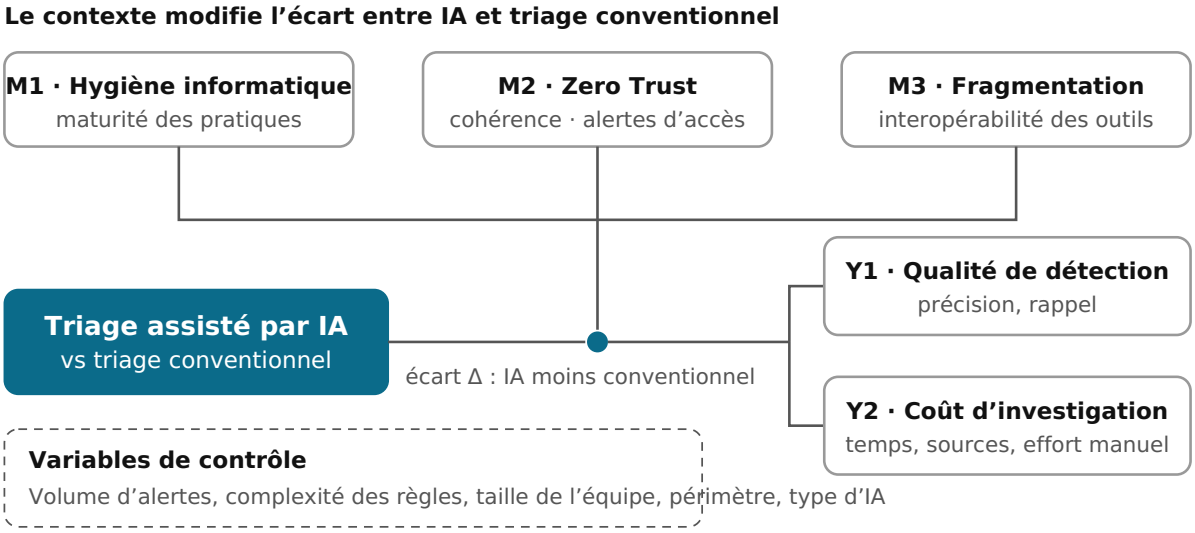
3.1 Définition du bruit informationnel

Le bruit informationnel désigne la part de l’information de sécurité qui, dans un contexte opérationnel donné, mobilise des ressources d’analyse sans contribuer proportionnellement à l’identification, à la qualification ou à la gestion des menaces pertinentes.

Cette définition est fonctionnelle. Une alerte non malveillante n’est pas forcément du bruit : elle peut vérifier la couverture d’un contrôle ou révéler une mauvaise configuration. Le bruit se juge au regard de la finalité de l’investigation, de la valeur du signal et de l’effort nécessaire à son exploitation. Il se distingue du volume, qui est une quantité, et de la fatigue des alertes, qui est une conséquence humaine possible d’une exposition répétée à une charge difficile à gérer.

3.2 Variables du modèle

Le modèle pose une question d’écart : l’IA fait-elle mieux ou moins cher qu’un triage conventionnel, et cet écart varie-t-il avec l’environnement ? Il retient une variable centrale, trois modérateurs, deux résultats et un ensemble de variables de contrôle. La figure ci-dessous en donne la structure et le tableau les définitions de travail.



modèle de modération · 1 variable centrale, 3 modérateurs, 2 résultats

Les trois modérateurs agissent sur l’écart entre IA et triage conventionnel, pas directement sur les résultats ; les variables de contrôle agissent sur les deux conditions comparées.

Rôle	Variable	Définition de travail
Centrale	Triage assisté par IA	Usage de l’IA pour prioriser, corréler ou synthétiser les alertes, comparé à un triage conventionnel fondé sur des règles et des procédures manuelles. Décrit par ses fonctions, son niveau d’automatisation et la supervision humaine.
Modérateur M1	Maturité de l’hygiène informatique	Complétude de l’inventaire des actifs, conformité des correctifs, maîtrise des comptes et des privilèges, configurations maintenues.
Modérateur M2	Cohérence de la mise en œuvre du Zero Trust	Harmonisation des politiques d’accès et intégration des données d’identité et de terminaux. Appliqué aux alertes liées aux identités et aux accès.
Modérateur M3	Fragmentation des outils	Faible interopérabilité effective : identifiants non communs pour un même actif, contexte dispersé, nombre d’interfaces à consulter par alerte.
Résultat Y1	Qualité de détection	Précision, rappel et taux de faux négatifs sur les alertes pertinentes.
Résultat Y2	Coût d’investigation	Temps de qualification, nombre de sources consultées, effort manuel par alerte.
Contrôle	Volume et configuration	Volume d’alertes, complexité de configuration des règles, taille et expérience de l’équipe, périmètre surveillé, type d’IA.

3.3 Lecture du modèle

Soit Δ l’écart de performance entre un triage assisté par IA et un triage conventionnel, mesuré séparément sur Y1 et sur Y2. Un modérateur est une variable qui fait varier Δ : l’effet de l’IA n’est pas supposé constant, il est supposé conditionnel. Le modèle ne dit pas que l’IA est efficace ou inefficace en général ; il dit où et à quelles conditions son effet change.

Trois précisions encadrent cette lecture.

1. Maturité et cohérence sont deux construits distincts. L’hygiène se mesure par une maturité de pratiques, le Zero Trust par la cohérence d’une architecture et de ses politiques. Ils seront opérationnalisés séparément (section 5).
2. Le volume et la complexité des règles sont des contrôles, non des objets d’étude. Ils influencent la charge d’alertes dans les deux conditions comparées, mais le cadre ne cherche pas à expliquer leur effet propre.
3. Des lectures concurrentes existent. L’hygiène peut aussi agir comme un facteur qui modifie le nombre d’alertes (effet direct), et les SOC les plus matures peuvent être ceux qui adoptent l’IA en premier (biais de sélection). Le protocole de la section 5 prévoit des comparaisons à l’intérieur d’un même SOC pour limiter ce second risque.

4. Propositions de recherche

Les quatre propositions suivantes sont des énoncés théoriques à tester, non des résultats. Chacune précise l'effet attendu, le mécanisme et ce qui la réfuterait. L'« avantage de l'IA » désigne, pour chaque résultat, l'écart favorable à l'IA par rapport au triage conventionnel : une qualité de détection plus élevée ou un coût d'investigation plus faible.

P1. Effet de référence : le gain porte d'abord sur le coût

Énoncé. En moyenne, le triage assisté par IA réduit le coût d'investigation (Y2) par rapport au triage conventionnel, mais cette réduction ne suffit pas à établir une amélioration de la qualité de détection (Y1), dont l'écart peut être nul, positif ou négatif.

Mécanisme. L'IA agit d'abord sur la rapidité de qualification par la priorisation et la synthèse. La qualité de détection dépend de la justesse des classements et du risque de masquer une alerte importante, risque connu des systèmes d'aide à la décision (Parasuraman et Manzey, 2010).

Réfutation. P1 est réfutée si le coût n'est pas inférieur sous IA, ou si l'avantage sur Y1 est positif de façon uniforme dans tous les environnements, ce qui rendrait inutile de distinguer les deux résultats.

P2. Hygiène informatique : l'avantage croît avec la maturité

Énoncé. À volume d'alertes contrôlé, l'avantage de l'IA sur Y1 et sur Y2 est d'autant plus grand que la maturité de l'hygiène informatique (M1) est élevée.

Mécanisme. Un inventaire complet, des comptes maîtrisés et des configurations stables permettent à l'IA de rattacher chaque alerte à un actif et à un responsable, et de s'appuyer sur des comportements de référence stables.

Précaution. Une meilleure hygiène peut révéler des événements jusque-là invisibles et accroître temporairement le nombre de détections ; d'où le contrôle du volume.

Réfutation. L'interaction entre l'usage de l'IA et M1 est nulle ou de signe opposé après contrôle du volume.

P3. Fragmentation des outils : l'avantage décroît, ou l'IA compense

Énoncé. L'avantage de l'IA sur Y1 et sur Y2 est d'autant plus faible que les outils sont fragmentés et peu interopérables (M3).

Mécanisme. Des identifiants incohérents et un contexte dispersé limitent la capacité de l'IA à rapprocher les données ; ses sorties reposent alors sur un contexte partiel.

Proposition concurrente. L'IA pourrait au contraire compenser la fragmentation en corrélant des sources dispersées que l'analyste doit sinon consulter une à une. L'avantage serait alors plus marqué en environnement fragmenté. Ces deux lectures s'opposent et sont discriminables par les données ; les départager est un apport possible de l'étude.

Réfutation. L'interaction entre l'usage de l'IA et M3 est nulle ou positive. Une interaction positive soutiendrait la lecture concurrente.

P4. Zero Trust : l'avantage croît avec la cohérence, pour les alertes d'accès

Énoncé. Pour les alertes liées aux identités et aux accès, l'avantage de l'IA sur Y1 et sur Y2 est d'autant plus grand que la mise en œuvre du Zero Trust (M2) est cohérente, c'est-à-dire que les politiques sont harmonisées et que les données d'identité et de terminaux sont intégrées.

Mécanisme. Les contrôles Zero Trust produisent du contexte exploitable pour qualifier une alerte d'accès : posture du terminal, risque de la session, décision d'accès appliquée.

Précaution. Des politiques mal harmonisées peuvent multiplier les refus et les changements de contexte, et réduire l'apport du Zero Trust au triage.

Réfutation. Aucune interaction pour ces alertes, ou une interaction de même ampleur pour des alertes sans lien avec les accès. Ce second cas indiquerait que le construit mesuré reflète une maturité générale plutôt que le Zero Trust.

Synthèse

Le cumul des trois modérateurs (interactions d'ordre supérieur) n'est pas formulé comme proposition : il est traité comme question exploratoire en section 7.

Proposition	Facteur	Effet attendu sur l'avantage de l'IA	Alertes concernées
P1	Aucun (effet de référence)	Avantage sur Y2 ; avantage sur Y1 non acquis	Toutes
P2	M1 Hygiène informatique	Croît avec la maturité	Toutes
P3	M3 Fragmentation des outils	Décroît avec la fragmentation (lecture concurrente : croît)	Toutes
P4	M2 Zero Trust	Croît avec la cohérence	Identités et accès

5. Méthodologie de validation proposée

La validation suit un enchaînement en trois phases, du plus exploratoire au plus contraignant. Une même logique la traverse : comparer l'IA et le triage conventionnel à l'intérieur de contextes qui diffèrent par leur hygiène, leur Zero Trust et leur fragmentation.

5.1 Phase 0. Revue ciblée reproductible

Une revue systématique restreinte, rapportée selon PRISMA 2020 (Page et al., 2021), vérifiera la lacune annoncée en section 1.1. Elle interrogera les croisements entre SOC, triage des alertes, IA, hygiène informatique, Zero Trust et intégration des outils, et documentera les bases, les équations de recherche, les critères d'inclusion et la sélection. Son résultat conditionne la formulation finale de la contribution.

5.2 Phase 1. Étude qualitative exploratoire

Des entretiens semi-directifs seront conduits auprès d'analystes SOC, de responsables de détection, de RSSI et de spécialistes de l'intégration des outils. Une cible de l'ordre de 12 à 20 entretiens dans 4 à 6 SOC différents (internes, prestataires, secteur public et privé) est proposée, jusqu'à saturation thématique. Les entretiens vérifieront que les modérateurs correspondent à des mécanismes réels, que les définitions de travail sont opérationnelles, et recueilleront des exemples de cas où l'IA a aidé ou gêné le triage.

5.3 Phase 2. Analyse multiniveau et rejeu contrôlé

Analyse multiniveau. Les alertes (niveau 1) sont imbriquées dans des SOC ou des périmètres clients (niveau 2). Les modérateurs M1, M2 et M3 sont mesurés au niveau 2 ; l'usage de l'IA varie à l'intérieur d'un même SOC lorsque c'est possible (avant et après déploiement, files de traitement avec et sans IA). On estime des modèles mixtes avec des termes d'interaction entre le niveau 1 et le niveau 2 (Raudenbush et Bryk, 2002 ; Hayes, 2018). La puissance des interactions de niveau 2 dépend du nombre de SOC ou de périmètres, non du nombre d'alertes. Si cet effectif est insuffisant pour estimer trois interactions, l'étude retiendra deux modérateurs, et les prestataires de services gérés, qui supervisent plusieurs clients aux niveaux de maturité différents, constituent une source de variation naturelle à explorer.

Rejeu contrôlé. Un jeu d'alertes étiqueté par des experts sert de vérité terrain. Des analystes le traitent avec ou sans assistance par IA, et l'on fait varier la qualité du contexte fourni (inventaire complet ou dégradé, identifiants communs ou non, données d'identité intégrées ou non). Cette manipulation permet d'approcher un effet causal des modérateurs sur l'avantage de l'IA, que les données de production ne permettent pas d'établir seules. Des scénarios injectés (par exemple issus d'exercices de simulation d'attaques) complètent le dispositif pour estimer le rappel, qui n'est pas observable en production.

5.4 Opérationnalisation

Les indicateurs seront fixés avant la collecte. Une baisse du nombre d'alertes ou du temps de traitement ne sera interprétée comme un gain que si le rappel n'est pas dégradé.

Construit	Indicateurs envisagés	Source
Triage assisté par IA	Fonctions assistées, niveau d'automatisation, supervision humaine, part des recommandations corrigées	Entretiens, journaux d'outil
M1 Hygiène	Score composite inspiré des mesures de l'ANSSI (2017) : couverture de l'inventaire, conformité des correctifs, revue des comptes et privilèges	Audit, données de gestion des actifs
M2 Zero Trust	Échelle inspirée des piliers identité et terminaux du modèle de la CISA (2023) et des principes de Rose et al. (2020) : cohérence des politiques, intégration des données	Audit, documentation d'architecture

M3 Fragmentation	Nombre d'interfaces consultées par alerte, part des actifs résolus sous un identifiant commun, délai d'obtention du contexte	Observation, journaux
Y1 Qualité de détection	Précision, rappel, taux de faux négatifs	Jeu étiqueté, scénarios injectés
Y2 Coût d'investigation	Temps médian de qualification, nombre de consultations croisées, effort manuel	Journaux, chronométrage
Contrôles	Volume d'alertes, complexité des règles, taille et expérience de l'équipe, périmètre, type d'IA	Données d'exploitation

5.5 Stratégie d'analyse

Une analyse descriptive caractérisera volumes, répartitions et différences entre contextes. Les modèles mixtes testeront l'interaction entre l'usage de l'IA et chaque modérateur, avec effets aléatoires par SOC et variables de contrôle ; P4 sera estimée sur les seules alertes d'identité et d'accès, puis comparée aux autres alertes comme test de spécificité. Des analyses de sensibilité feront varier la définition des indicateurs, et les comparaisons multiples seront corrigées. Le déploiement de l'IA n'étant pas aléatoire et les SOC les plus matures pouvant l'adopter les premiers, la maturité est modélisée explicitement et les comparaisons intra-SOC sont privilégiées. Aucun résultat ne peut être anticipé avant la collecte.

5.6 Éthique et confidentialité

Les données d'alertes sont sensibles et peuvent contenir des données à caractère personnel. L'étude exigera des accords de confidentialité avec les organisations, l'anonymisation ou la pseudonymisation des journaux, et des données agrégées pour les temps de traitement afin de ne pas évaluer individuellement les analystes. Les entretiens feront l'objet d'un consentement éclairé.

6. Discussion

6.1 Apports théoriques

Le cadre déplace la question de recherche du volume vers la valeur conditionnelle de l'IA. Au lieu de demander si l'IA réduit la fatigue des alertes, il demande dans quel contexte elle améliore la détection et réduit le coût d'investigation. Cette reformulation a trois conséquences.

1. L'IA est traitée comme une capacité de traitement insérée dans un environnement, non comme une solution isolée. Son effet est conditionnel, et c'est cette conditionnalité qui est testée.
2. Un gain de productivité n'est pas un gain de sécurité. En mesurant ensemble Y1 et Y2, le cadre empêche de conclure à la performance d'une IA qui réduirait le temps de traitement en laissant passer plus de menaces.
3. Une lecture concurrente est formulée dès le départ. Pour la fragmentation, P3 et sa proposition concurrente prédisent des signes opposés, ce qui rend le cadre falsifiable sur un point où l'intuition des praticiens diverge.

6.2 Implications pour la gouvernance cyber

Les responsables de la sécurité et de SOC peuvent tirer du cadre une grille de diagnostic avant d'investir dans une couche d'IA. Les difficultés observées proviennent-elles de règles mal calibrées, d'un inventaire incomplet, de comptes mal maîtrisés, d'outils non interopérables ou d'un manque de procédures ? Si la réponse relève de l'environnement, l'IA risque de produire un gain de vitesse sans gain de détection, et de rendre plus difficile le repérage des défauts qu'elle automatise.

Le cadre suggère aussi de compléter les indicateurs de volume par des mesures de pertinence, de contexte, de coût de qualification et de performance décisionnelle, et de réserver à la supervision humaine les cas ambigus. Il ne s'oppose pas à l'innovation : il cherche à déterminer les conditions dans lesquelles elle produit une amélioration mesurable.

6.3 Séquencement des investissements

Si P2 et P4 se vérifient, l'hygiène informatique et la cohérence du Zero Trust ne sont pas seulement des objectifs de sécurité autonomes : elles augmentent le rendement des investissements en IA de détection. Si P3 est soutenue, l'intégration des outils précède l'IA. Si c'est la proposition concurrente qui l'emporte, l'IA peut au contraire être un palliatif à court terme de la

fragmentation. Dans les deux cas, la décision d'investissement gagne à s'appuyer sur un diagnostic du contexte et non sur la seule promesse de l'outil.

7. Limites et perspectives

7.1 Limites

Statut du manuscrit. L'article est conceptuel. Il ne repose sur aucune donnée originale et ses propositions ne sont pas établies. La revue de la littérature est préliminaire et doit être remplacée par la revue reproductible de la phase 0.

Validité de construit. Hygiène, cohérence du Zero Trust et fragmentation sont des construits composites dont la mesure dépend du contexte. Les échelles proposées s'inspirent de référentiels (ANSSI, 2017 ; CISA, 2023) qui n'ont pas été conçus pour mesurer des modérateurs de l'efficacité de l'IA et devront être validées.

Portée du Zero Trust. Le modérateur M2 ne s'applique qu'aux alertes d'identité et d'accès. Il ne dit rien du triage des autres familles d'alertes.

Vérité terrain. La précision et le rappel exigent une référence fiable sur les événements pertinents. En production, le rappel n'est pas observable et repose sur des scénarios injectés, dont la représentativité est limitée.

Sélection et causalité. Le déploiement de l'IA n'est pas aléatoire. Les comparaisons intra-SOC et le rejeu contrôlé limitent le biais sans l'éliminer.

Hétérogénéité de l'IA. Les classifieurs d'apprentissage automatique, les moteurs de corrélation et les assistants fondés sur des modèles de langage n'ont ni les mêmes forces ni les mêmes défauts, et évoluent vite. Le type d'IA est un contrôle, mais ses résultats pourraient ne pas se transposer d'une génération d'outils à l'autre.

Généralisation. Les SOC internes, les prestataires et les structures publiques diffèrent par leurs ressources et leurs objectifs. Les comparaisons doivent en tenir compte.

7.2 Perspectives

Interactions d'ordre supérieur. Les effets des trois modérateurs se cumulent-ils, se compensent-ils, ou l'un d'eux suffit-il ? La question est exploratoire et demande un échantillon plus large que celui d'une première étude.

Dimension temporelle. La maturité évolue. Une étude longitudinale pourrait suivre l'avantage de l'IA lorsque l'hygiène, le Zero Trust ou l'intégration des outils s'améliorent.

Facteurs humains. L'effet de la supervision humaine, de la confiance excessive et de la complaisance sur Y1 pourrait être modélisé comme un médiateur ou un modérateur supplémentaire.

Adaptation des adversaires. Une IA de triage peut devenir une cible. L'extension du cadre à la robustesse face à des attaques visant la détection mérite un travail propre.

8. Conclusion

Cet article propose de déplacer l'analyse de la fatigue des alertes du volume vers la valeur conditionnelle de l'intelligence artificielle. Il formule une question précise : si et comment l'hygiène informatique, la cohérence du Zero Trust et la fragmentation des outils modifient l'effet de l'IA sur le triage, en matière de qualité de détection et de coût d'investigation.

La proposition centrale est que la valeur opérationnelle de l'IA dans un SOC dépend non seulement de ses capacités propres, mais aussi de la qualité de configuration, d'intégration et de contextualisation de l'environnement dans lequel elle intervient. Quatre propositions falsifiables, dont une opposant deux lectures de l'effet de la fragmentation, et un protocole en trois phases permettent de la mettre à l'épreuve.

Si elle se vérifie, la question à poser avant d'ajouter une couche d'IA n'est plus seulement ce que l'outil sait faire, mais ce que l'environnement lui permet de faire. Si elle est réfutée, le cadre aura au moins précisé les conditions dans lesquelles l'IA apporte un gain mesurable indépendamment du contexte, ce qui constituerait aussi un résultat utile.

Bibliographie

Agence nationale de la sécurité des systèmes d'information (ANSSI). (2017). Guide d'hygiène informatique : renforcer la sécurité de son système d'information en 42 mesures (version 2.0). ANSSI.

Alahmadi, B. A., Axon, L., & Martinovic, I. (2022). 99% false positives: A qualitative study of SOC analysts' perspectives on security alarms. Proceedings of the 31st USENIX Security Symposium. USENIX Association.

Chhetri, M. B., Tariq, S., Singh, R., Jalalvand, F., Paris, C., & Nepal, S. (2024). Towards human-AI teaming to mitigate alert fatigue in Security Operations Centres. ACM Transactions on Internet Technology, 24(3), Article 12, 1–22. https://doi.org/10.1145/3670009

Cybersecurity and Infrastructure Security Agency (CISA). (2023). Zero Trust Maturity Model, Version 2.0. CISA.

Hayes, A. F. (2018). Introduction to mediation, moderation, and conditional process analysis: A regression-based approach (2nd ed.). Guilford Press.

Kokulu, F. B., Soneji, A., Bao, T., Shoshitaishvili, Y., Zhao, Z., Doupé, A., & Ahn, G.-J. (2019). Matched and mismatched SOCs: A qualitative study on Security Operations Center issues. Proceedings of the 2019 ACM SIGSAC Conference on Computer and Communications Security. ACM.

Ofte, H. J., & Katsikas, S. (2023). Understanding situation awareness in SOCs: A systematic literature review. Computers & Security, 126, 103069. https://doi.org/10.1016/j.cose.2022.103069

Page, M. J., McKenzie, J. E., Bossuyt, P. M., Boutron, I., Hoffmann, T. C., Mulrow, C. D., et al. (2021). The PRISMA 2020 statement: An updated guideline for reporting systematic reviews. BMJ, 372, n71. https://doi.org/10.1136/bmj.n71

Parasuraman, R., & Manzey, D. H. (2010). Complacency and bias in human use of automation: An attentional integration. Human Factors, 52(3), 381–410.

Parasuraman, R., & Riley, V. (1997). Humans and automation: Use, misuse, disuse, abuse. Human Factors, 39(2), 230–253.

Raudenbush, S. W., & Bryk, A. S. (2002). Hierarchical linear models: Applications and data analysis methods (2nd ed.). Sage.

Rose, S., Borchert, O., Mitchell, S., & Connelly, S. (2020). Zero Trust Architecture (NIST Special Publication 800-207). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.SP.800-207

Tariq, S., Baruwal Chhetri, M., Nepal, S., & Paris, C. (2025). Alert fatigue in Security Operations Centres: Research challenges and opportunities. ACM Computing Surveys, 57(9), Article 224, 1–38. https://doi.org/10.1145/3723158

Vielberth, M., Böhm, F., Fichtinger, I., & Pernul, G. (2020). Security Operations Center: A systematic study and open challenges. IEEE Access, 8, 227756–227779.